



RELATÓRIO DO AMBIENTE CONSTRUÍDO HOSPITAL VIDA PLENA

Equipe: AptX Team

Integrantes: Eduardo Gutierrez, Felipe Ribeiro de Carvalho, Leonardo Oliveira Feitosa, Matheus Patrick, Renan Ribeiro Almeida.

Contexto: Fase de Preparação (*Preparation*) do Ciclo de Resposta a Incidentes.

Sumário:

1. Descrição Geral do Ambiente:	2
2. Arquitetura Detalhada:	3
3. Infraestrutura e Tecnologias Utilizadas:	4
4. Configurações Realizadas:	6
5. Políticas de Log Ativas:	8
6. Vulnerabilidades intencionais:	9
7. Plano de Ataque Controlado:	10
8. Plano de Logging e Coleta de Evidências:	11

1. Descrição Geral do Ambiente:

1. Tipo de Organização Simulada: Ambiente hospitalar crítico (Simulação do "Hospital Vida Plena").
2. Objetivo do Ambiente: Fornecer um laboratório controlado e isolado para simular um ataque cibernético baseado em engenharia social (phishing) e subsequente movimentação lateral com infecção por Ransomware (simulando o comportamento do WannaCry), permitindo a posterior análise forense e resposta a incidentes.
3. Escopo do Laboratório: O ambiente é composto por um perímetro protegido por firewall virtualização, um controlador de domínio para gestão de identidades, estações de trabalho médicas, repositórios de prontuários, servidores de exames e uma estrutura de backup.
4. Limitações Técnicas: Ambiente hospedado localmente sob um único Hypervisor físico, limitando a redundância de hardware e simulando o link de internet através de uma interface em modo bridge.
5. Hipóteses Consideradas: Assume-se que o elo mais fraco da cadeia (o usuário/médico) será comprometido via engenharia social externa, assumindo que as defesas de e-mail de borda falharam ou foram contornadas.

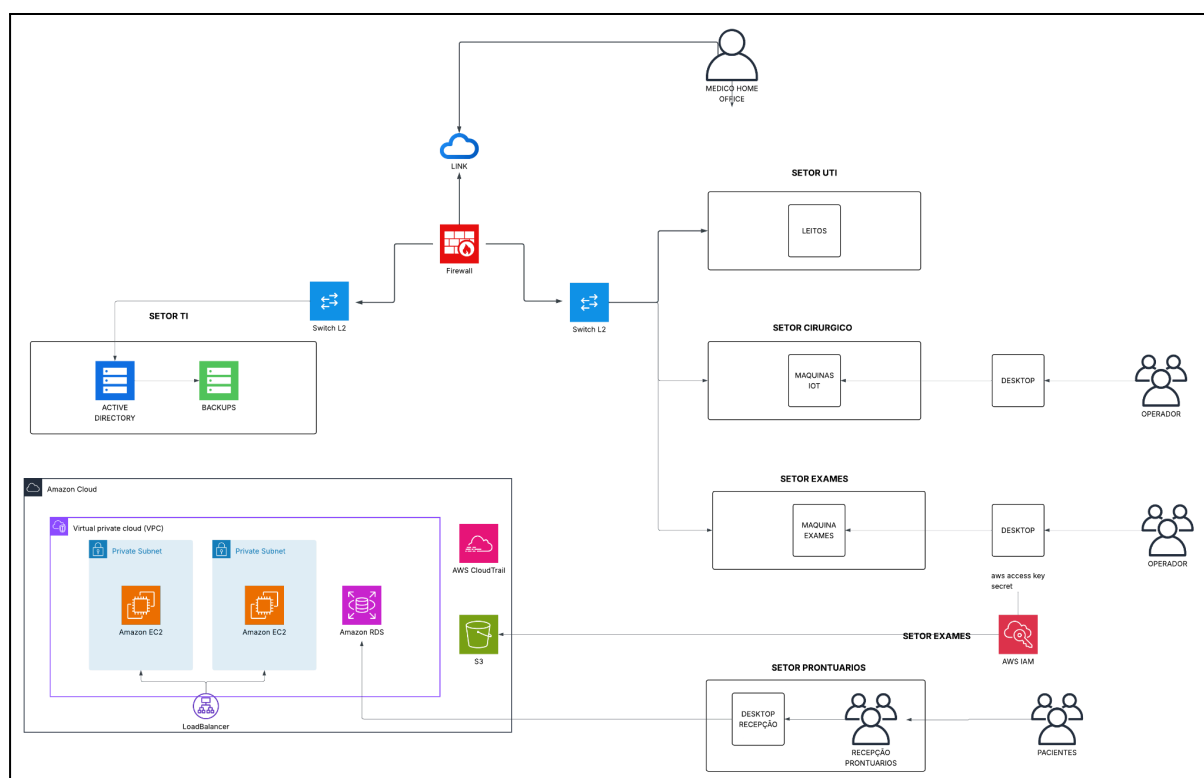
2. Arquitetura Detalhada:

A arquitetura do ambiente foi construída utilizando o hypervisor Proxmox VE como plataforma principal de virtualização, permitindo o gerenciamento e isolamento das máquinas virtuais do laboratório em um único host físico.

O controle e a segmentação do tráfego de rede são realizados por meio do appliance virtual OPNSense, configurado como Firewall/Gateway principal do ambiente. O OPNSense é responsável pelo roteamento entre redes, aplicação de regras de firewall, NAT e controle de acesso entre os segmentos da infraestrutura virtualizada.

A topologia foi estruturada com duas interfaces de rede principais:

- **Interface WAN:** configurada em modo *Bridge* com a rede local corporativa do SENAI, simulando o link de saída para a Internet e permitindo o tráfego externo (*outbound traffic*).
- **Interface LAN:** rede interna isolada e gerenciada pelo OPNSense, onde estão concentradas as máquinas virtuais e os dados sensíveis do Hospital Vida Plena, permitindo maior controle e segurança do tráfego interno.

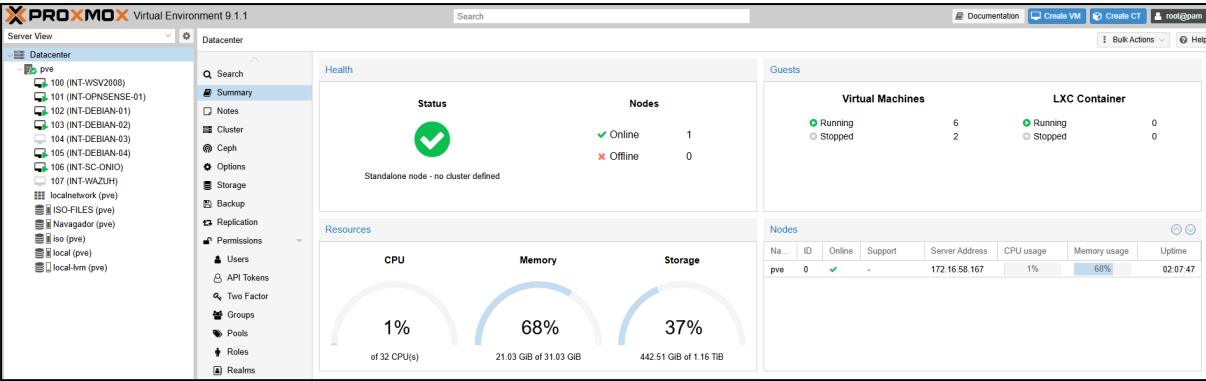


Anexo 1: Topologia do ambiente.

3. Infraestrutura e Tecnologias Utilizadas:

A tabela abaixo detalha a matriz de ativos, sistemas operacionais e funções mapeadas no laboratório:

Ativo / Host:	Sistema:	Serviços Ativos / Função:	Portas Expostas:
OPNSense	FreeBSD (Custom)	Firewall, Gateway, Roteamento, NAT	Web GUI (443), SSH (22)
WinServer 2008	Windows Server 2008	Active Directory (AD DS), DNS, IIS (Web), FileShare (SMBv1)	53 (DNS), 88 (Kerberos), 445 (SMB), 389 (LDAP), 80 (HTTP)
Debian 01	Debian GNU/Linux	Simulação de Máquina/Equipamento de Exames	SSH (22)
Debian 02	Debian GNU/Linux	Simulação do Centro de Armazenamento de Prontuários	SSH (22), HTTP/S ou custom
Debian 03	Debian GNU/Linux	Servidor de Armazenamento de Backup do Hospital	SSH (22)
Debian 04	Debian GNU/Linux	Estação da Recepção / Concentrador de Logs Ativos	SSH (22)
W11 Médico	Windows 11	Estação de Trabalho do Corpo Clínico (Alvo Inicial)	RDP (3389)



Anexo 2: Arquitetura montada.

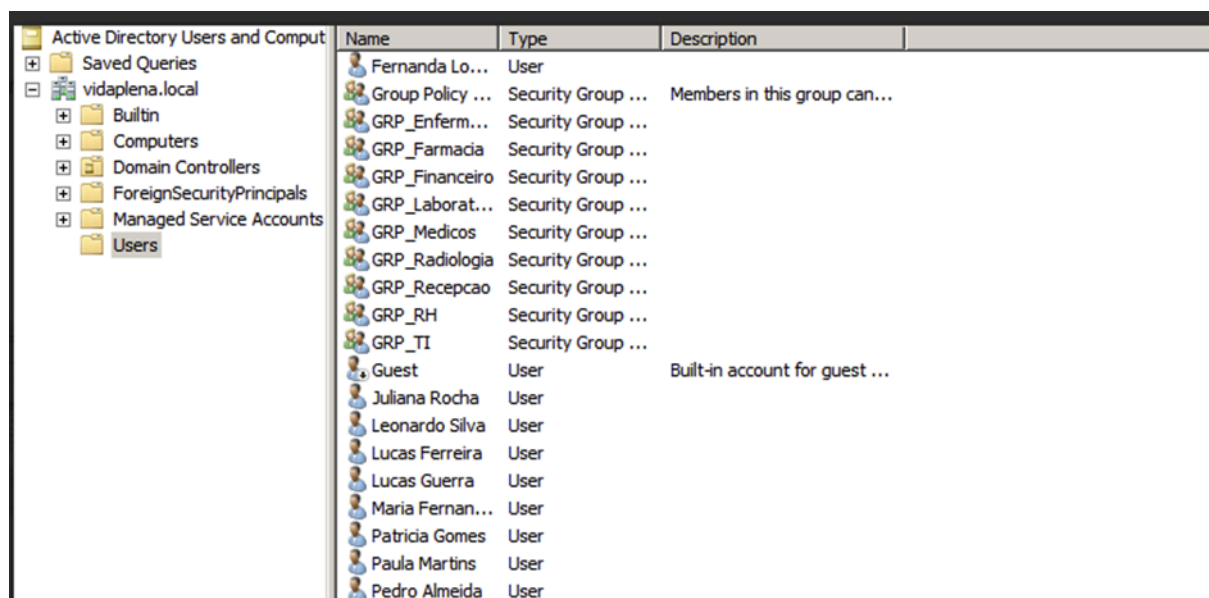
4. Configurações Realizadas:

Configurações de Autenticação e Diretório:

- Implementação do Active Directory (AD) no Windows Server 2008 para centralização de credenciais.
- Criação de usuários baseados na hierarquia hospitalar (médicos, recepção, administradores) e estruturação de grupos de segurança.
- Criação de um diretório de arquivos compartilhados (*FileShare*) personalizado para o hospital (Pastas: */Exames*, */Prontuarios*).

Configurações de Rede e Perímetro:

- O Firewall OPNSense foi implementado inicialmente sem segmentação interna de redes e com regras permissivas (*Any-to-Any* na LAN).
- Alinhamento com Boas Práticas: O isolamento da WAN em relação ao ambiente de produção do SENAI garante que artefatos maliciosos não vazem da rede controlada.
- Configurações Propositalmente Fragilizadas: Ausência de DMZ para os servidores internos, permissões excessivas de escrita nas pastas do *FileShare* para o grupo de usuários clínicos, e falta de regras restritivas de tráfego interno (permitindo que qualquer máquina fale com qualquer servidor).



	Name	Type	Description
Active Directory Users and Comput	Fernanda Lo...	User	
+ Saved Queries	Group Policy ...	Security Group ...	Members in this group can...
+ vidaplana.local	GRP_Enferm...	Security Group ...	
+ Builtin	GRP_Farmacia	Security Group ...	
+ Computers	GRP_Financeiro	Security Group ...	
+ Domain Controllers	GRP_Laborat...	Security Group ...	
+ ForeignSecurityPrincipals	GRP_Medicos	Security Group ...	
+ Managed Service Accounts	GRP_Radiologia	Security Group ...	
+ Users	GRP_Recepcao	Security Group ...	
	GRP_RH	Security Group ...	
	GRP_TI	Security Group ...	
	Guest	User	Built-in account for guest ...
	Juliana Rocha	User	
	Leonardo Silva	User	
	Lucas Ferreira	User	
	Lucas Guerra	User	
	Maria Fernan...	User	
	Patricia Gomes	User	
	Paula Martins	User	
	Pedro Almeida	User	

Anexo 3: Usuários e grupos do AD.

```
Administrator: Command Prompt
C:\VidaPlena>
C:\VidaPlena>
C:\VidaPlena>tree
Folder PATH listing
Volume serial number is DCC9-32BC
C:
├── Enfermagem
├── Farmacia
├── Financeiro
├── Laboratorio
├── Prontuarios
├── Publico
├── Radiologia
├── Recepcao
├── RH
└── TI
```

Anexo 4: Diretório criado.

5. Políticas de Log Ativas:

Para garantir a capacidade de detecção e posterior resposta a incidentes, os seguintes mecanismos de auditoria foram preparados:

- **Ambiente Windows (Windows Server 2008 & Windows 11):** Ativação do *Windows Event Manager* com foco em logs de Segurança (*Security.evtx*), rastreando falhas e sucessos de autenticação (Event IDs 4624, 4625), criação de processos e modificação de arquivos.
- **Ambiente Linux (Debian 01 a 04):** Monitoramento através de logs locais tradicionais do sistema armazenados em */var/log/syslog* e */var/log/auth.log* (para tentativas de acesso SSH).
- **Deficiência Estrutural Planejada (Gap de Visibilidade):** Os logs estão descentralizados e locais em cada máquina (com exceção do Debian 04 que possui logs de sistema básicos). Não há um correlacionador de eventos (SIEM) ativo, regras de alerta em tempo real ou monitoramento de integridade de arquivos (FIM), simulando a realidade de um hospital negligente em maturidade cibernética.

6. Vulnerabilidades intencionais:

Para possibilitar a execução controlada do cenário de ataque e permitir a análise prática das técnicas utilizadas, o ambiente foi propositalmente configurado com vulnerabilidades conhecidas e falhas de segurança específicas.

SMBv1 habilitado no servidor FileShare:

Foi mantido ativo o protocolo SMBv1, versão obsoleta e vulnerável do serviço de compartilhamento de arquivos em rede. Essa configuração permite demonstrar técnicas clássicas de movimentação lateral automatizada, incluindo explorações semelhantes ao exploit EternalBlue, amplamente associado ao ransomware WannaCry. O risco associado é considerado crítico, pois possibilita execução remota de código (RCE) com privilégios elevados.

Utilização de sistema operacional legado (Windows Server 2008):

O ambiente utiliza o Windows Server 2008, sistema operacional em fim de vida útil (EOL), sem suporte oficial e sem atualizações de segurança recentes. A proposta pedagógica é representar cenários comuns em ambientes hospitalares que ainda dependem de sistemas legados devido à incompatibilidade com equipamentos ou softwares específicos. Essa condição aumenta significativamente a exposição a vulnerabilidades conhecidas e sem correção.

Permissões excessivas e ACLs mal configuradas:

As permissões de acesso no FileShare foram configuradas de forma inadequada, permitindo direitos amplos de leitura, modificação e escrita para usuários comuns. O objetivo é demonstrar os impactos da ausência do Princípio do Menor Privilégio (*Principle of Least Privilege*), evidenciando como permissões excessivas ampliam o alcance e os danos de ataques de criptografia de arquivos.

Ausência de segmentação de rede e proteção de endpoints:

A infraestrutura foi configurada sem mecanismos avançados de segmentação interna, como VLANs ou microsegmentação, além da ausência de soluções EDR (*Endpoint Detection and Response*). Essa abordagem permite demonstrar como um malware pode se propagar livremente pela rede interna após comprometer um único ativo, aumentando o impacto operacional do incidente.

7. Plano de Ataque Controlado:

Tipo de Ataque:

Simulação controlada de infecção por ransomware no estilo WannaCry, precedida pelo comprometimento de credenciais por meio de técnicas de engenharia social.

Vetor de Ataque Inicial:

O cenário inicia com uma simulação de phishing direcionada à estação de trabalho do médico, utilizando Windows 11. Após a execução do artefato malicioso simulado pelo usuário, é estabelecido um acesso remoto controlado ao ambiente, simulando uma conexão do tipo Reverse Shell/C2.

Técnicas Simuladas:

Inicialmente são executadas técnicas de reconhecimento do sistema e coleta de credenciais locais na máquina comprometida. Em seguida, o acesso obtido é utilizado para identificar compartilhamentos de rede ativos e recursos acessíveis no ambiente. Por fim, um script/binário simulando comportamento de ransomware é executado para criptografar arquivos locais e remotos presentes nas pastas de exames e prontuários.

Alvos do Cenário:

O ataque possui como foco a estação do médico em Windows 11, o servidor de arquivos baseado em Windows Server 2008 e o servidor de prontuários em Debian.

Impacto Esperado:

A simulação busca demonstrar a indisponibilidade dos sistemas de arquivos hospitalares, comprometendo o acesso a exames, documentos e prontuários médicos armazenados na rede.

Critérios de Segurança e Rollback:

Toda a execução será limitada exclusivamente às pastas de simulação definidas no laboratório. Como mecanismo de segurança, snapshots completos das máquinas virtuais serão realizados previamente no Proxmox VE, permitindo a restauração imediata do ambiente ao estado original após a conclusão dos testes.

8. Plano de Logging e Coleta de Evidências:

Para garantir a rastreabilidade das ações executadas durante a simulação de ataque, foi definido um processo de logging e coleta de evidências focado no servidor de arquivos em Windows Server 2008.

Durante a execução do cenário, serão monitorados os principais eventos relacionados a autenticação, acesso a arquivos, compartilhamentos SMB e execução de processos no servidor. Os logs coletados permitirão identificar tentativas de acesso, movimentação lateral, alterações em arquivos e possíveis atividades associadas ao comportamento do ransomware simulado.

Os principais registros monitorados incluem:

- Logs de autenticação e tentativas de login;
- Eventos de acesso ao FileShare e compartilhamentos SMB;
- Registros de criação e execução de processos;
- Logs de modificação, exclusão e criptografia de arquivos;
- Eventos de acesso remoto e conexões de rede;
- Alertas de comportamento suspeito identificados durante a simulação.

Como forma de preservação das evidências e recuperação rápida do ambiente, snapshots das máquinas virtuais serão criados previamente no Proxmox VE antes da execução dos testes.